

等级保护2.0时代电力系统身份安全问题初探

谭 宽, 张媛琳

(云南电网有限责任公司红河供电局, 云南红河 661100)

[摘要] 信息化进程的逐步加快, 使网络防护和数据保护等受到了广泛关注, 用户个人信息的安全保护一直处于弱势地位, 常常被选择性忽略, 以至于呈现出信息安全短板。文章重点结合等级保护2.0时代的背景加以分析, 明确电力系统身份安全问题, 通过概述等级保护2.0的基本特征, 分析其对于电力系统身份安全带来的巨大挑战, 提出针对性的应对策略, 构建起完善的攻防对抗机制, 确保电力系统的身份安全问题得到有效处理。

[关键词] 等级保护2.0; 电力系统; 身份安全

[中图分类号] TM73

[文献标志码] A

[文章编号] 1001-523X (2020) 15-0160-02

A Preliminary Study on the Identity Security of Power System in the Age of Hierarchical Protection 2.0

Tan Kuan, Zhang Yuan-lin

[Abstract] Faced with the gradual acceleration of the informatization process, network protection and data protection have received extensive attention. The security protection of users' personal information is often in a weak position, and it is often overlooked selectively, so that it presents a shortcoming in information security. This article focuses on the analysis of the background of the hierarchical protection 2.0 era, clarifies the identity security issues of the power system, by summarizing the basic characteristics of the hierarchical protection 2.0, analyzes the huge challenges it brings to the identity security of the power system, proposes a targeted response strategy, and builds a perfect The offensive and defensive confrontation mechanism ensures that the identity security of the power system is effectively dealt with.

[Keywords] Level Protection 2.0; power system; identity security

在电网互联稳步发展的进程中, 各个地区的供电企业和单位需要具备较为合理的网络平台, 才能确保电力企业相关业务的开展更加顺利。但由于不同地区的供电企业和单位局域网和城域网缺乏足够的安全性, 在面对安全威胁的时候, 未能采取合理的应对方案, 相应的预警机制不够健全, 影响到具体工作的顺利落实, 也直接影响到电力系统的实际运行。电力部门对外开放的接口呈现出逐步增多的趋势, 在落实了双网隔离之后, 难以更好地应对多种变化和升级, 使基本工作的开展受到威胁, 电力系统身份安全仍然是亟待处理的问题。企业在实际运营中, 通常需要接触到安全等级较低的外网, 整个业务开展的过程中, 身份安全面临着巨大的考验, 极易出现恶意攻击与利用的情况, 进而导致难以挽回的经济损失。

1 等级保护2.0时代的到来

Imperva 的相关调查显示, 73% 的电力企业员工认为可以轻松访问到相对敏感的内部数据信息。Facebook 安全事件使用户的信息出现了明显的泄露, 因此受到了惩罚, 罚款 50 亿美元。身份安全验证属于一种重要的保障措施, 能够避免信息的泄露问题, 采取何种方式维护身份信息的安全性是当前较为棘手的问题。2019年5月10日, 等级保护2.0正式发布, 于2019年12月1日正式实施。等级保护2.0的出现和实施是强化信息保护能力的重要措施, 能够严格地贯彻并落实《中华人民共和国网络安全法》是网络安全战略目标的基础。等级保护2.0相比旧标准来说, 实现了较为明显的突破, 获得了十足的进展, 特别是在移动互联网和云计算等方面提供了专业的指导与帮助, 为电力系统网络安全构建指明了方向。

2 等级保护2.0时代的基本特征

2.1 基本要求

在基本要求上, 等级保护2.0新标准提出了新的要求, 确保了测评和安全设计技术趋向统一, 拥有相对理想的框架, 证明了安全管理中心具备的三重防护结构。

2.2 新型要求

等级保护2.0除了体现出基本的通用安全要求外, 还将新型应用安全扩展要求进行了适当的分析与考量, 其中涉及到云计算、移动互联以及物联网等, 均被合理地纳入标准规范中, 着重体现出相关的新型方针。

2.3 功能要求

在等级保护2.0中, 新的标准对于功能要求进行了适当的完善与优化, 将可信计算和验证合理列入各个级别以及各个环节的主要功能要求中, 使其成为了至关重要的组成部分。其中, 可信计算的主要思想就是在计算机系统内部合理地构建起信任根, 其本身的可信性是由物理安全和技术安全等共同发挥作用。之后, 建立起完整的信任链, 由信任根到软件平台、操作系统等, 逐步扩展至计算机系统, 由此使计算机系统的可信度更加理想。可信计算使身份安全获取了较为可靠的保障。相比于等级保护1.0来说, 等级保护2.0中适当增加了可信计算的具体要求及标准。

3 电力系统身份安全面临的挑战

3.1 不具备身份标准规范

身份标准规范的缺乏通常表现在权威身份数据的确认上, 同时也不具备较为完整的身份认证统一标准, 以至于在身份信息的确认和验证上, 忽视了重要的环节和流程, 缺少科学合理的规范与要求。

3.2 缺少完整的管控流程

在合理的管理与控制体系中, 需要强化对相关人员的录转调离管控, 同时还应该针对于权限问题展开科学的确认与分析, 权限最小化管控流程也是一个重要方面, 需要将此项工作严谨地落实到实处。对外部人员的管理以及应用上线的管控等, 需要采取合理的措施积极推进相关工作, 但是目前来看, 具体的管控工作缺乏完整性和合理性, 流程不够严谨, 影响到实际的开展成效。

3.3 缺少科学的技术支持

一般来说, 在电力系统中, 身份信息的安全保护需要依

靠完整的技术流程,通过强化技术的实际效力,确保身份信息安全的保护成果更加理想。目前,缺乏较为完整的自助服务,在工作实践中多是依靠着员工们的自觉意识,通过记忆账号、密码等信息,维护相关的身份信息安全,但此类方式体现出较为明显的主观性。因缺少统一的登录入口,使相关工作的开展面临着极大的考验。

3.4 身份信息的混乱状态

电力系统的身份信息一旦出现混乱的状态,多表现在应用系统较多,不同系统有着不同的账号,无法进行合理地识别与分析。内外部用户数量庞大,涵盖着集成商和供应商等多个主体,关键资源的特权账号在实际管理的过程中,表现出一定的混乱。

3.5 相关标准形同虚设

具体的标准在实际执行的时候,缺乏基本的效力,加之部分标准形同虚设,通常表现在将部分复杂的密码记录于纸上,未能按照标准进行明确登记,甚至在工作过程中,将账号出借他人,出现钓鱼问题。

4 等级保护2.0时代电力系统身份安全防护措施

在等级保护2.0时代背景下,电力系统身份信息安全防护成为了至关重要的问题,受到了广泛的关注与认可,应该采取合理的防护措施,选择适宜的方案,保证电力系统身份安全得到保障,促使电力系统呈现出较为稳定的运行状态,达到理想的运行目的,满足当前国家对电力企业提出的基本要求。

4.1 积极落实身份鉴别操作

对登录的用户,应该积极落实身份鉴别处理,因为身份标识具有唯一性,所以有效的鉴别能够保证身份信息安全,需要注意身份鉴别信息的定期更换和维护。还需要具备基础性的登录失败处理功能,应该根据实际需要,合理配置并启用结束会话的相关功能,通过完善具体措施,确保身份信息得以安全保障。在进行远程管理的时候,需要重视科学的措施,适当规避鉴别信息在传输阶段被窃听的情况,借助于口令和密码技术等手段,使用户的身份鉴别更加到位。

4.2 重视可信验证的落实情况

应该在可信根的基础上,针对计算设备的相关系统引导程序展开合理的分析与判断,同时明确具体的系统程序和重要配置参数等进行可信验证方案,根据实际需要,明确应用程序关键执行环节的基本要领,做好动态可信验证处理,在分析可信性的基础上,进行报警处理,及时对危险情况遏制。之后将相关的验证结果形成完整的审计记录,传递给安全管理中心,确保相关工作的开展提供更为可靠的参考依据,在开展相应任务时,能够具备可靠的信息支撑。

4.3 进行访问控制处理操作

需要针对登录用户,进行合理的分配与分析,根据实际需要,将账户和权限等进行适当的匹配,实现科学合理的处理与规范,促使相关工作的开展更具保障。在实际工作中,需要重命名或者及时删除默认账户,更改账户的默认口令,同时还需要根据实际的需求,删除或者是停用多余的账户,保证规避一些干扰因素。根据工作需求,授予管理用户实际需要的最小权限,管理用户的权限能够实现有效分离。访问控制的力度需要确保主体为用户级,客体则应该达到文件、数据库表级。需要依照主体和客体实际需求,合理设置安全标记,由此更好地进行科学化的处理操作。通过将上述相关举措扎实地落实到实处,可以对主体进行适当的控制,使其及时进入到富有安全标记的信息领域进行访问。

4.4 做好安全审计处理工作

根据具体工作需要,应该及时将安全审计功能启用到位,审计一般会覆盖多个用户,针对用户的实际行为以及安全事件等可以展开合理分析,因此需要重视相应的审计处理与维护。审计记录需要涵盖事件的日期和时间等,对相关事件进行判断,分析其是否成功,是保证各个主体信息安全的关键。需要对审计记录进行科学的保护与分析,实现定期的备份与处理,以免出现未逾期删除的情况,还需对审计进程实现科学的保护,避免未经授权时出现中断的情况。

4.5 强化数据信息的保密性

借助于合理的密码技术,确保相关数据信息在传输时的保密程度,实现科学有效的防护,以免出现信息泄露。整个操作中,包含但不限于鉴别数据信息和重要数据信息等,借助于科学的密码技术,对重要信息进行合理维护,使相关信息更加可靠,并得到有效保障,在实际存储的时候,更具保密性。运用保密技术的时候,除了鉴别数据信息外,还会对重要的个人信息展开分析,使数据信息独立性和保密性的效果更佳。

4.6 注重数据信息的完整性

可以适当运用校验技术或者具体的密码技术,对极为重要的信息展开合理的保护,使重要的数据信息能够得到有效保障,在实际传输时,可以确保自身的完整性。对数据信息完整性的保护,除了鉴别相关的数据信息外,还需重视校验技术及密码技术的作用,存储过程中的完整性是至关重要的,涉及到的信息内容除了重要的业务数据和审计数据外,也有个人相关资料。

4.7 对个人信息的保护

需要重视采集和保存业务需要的用户个人信息,采取合理的方式对用户个人信息进行适当的防护,确保信息的内容得到有效梳理,同时避开一系列干扰,完善相应的细节与管理过程,促使个人信息的保护效更加理想。针对于登录过程,应该做好严谨防护,禁止未授权的访问以及非法使用用户个人信息的行为。

5 结束语

等级保护2.0时代的到来为电力系统身份安全提供了可靠的保障,其体现出的普适性获得了大众的认可,覆盖的行业范围较广,技术领域涉及较大,能够为电力企业及其他行业的发展保驾护航。等级保护2.0让企业网络安全战略的规划目标得以实现,同时逐步优化了网络安全手段,使管理人员获得了更为明显的指引。本文重点概述了等级保护2.0的相关特征,同时分析了电力系统身份安全面临的挑战,提出了合理化的建议与对策,旨在为电力系统的网络安全建设提供有效的参考意见,使其获得有效的技术和理论支撑。

参考文献

- [1] 何金军.从被测单位的视角论述网络安全等级保护制度的重要性[J].网络安全技术与应用,2020(5):6-7.
- [2] 郭乐.网络安全等级保护2.0体系下的法院网络安全管理及应对[J].网络安全技术与应用,2020(5):136-137.
- [3] 郭乐.基于网络安全等级保护2.0版本的法院信息安全存在的隐患及要求[J].网络安全技术与应用,2020(4):150-151.
- [4] 王晔,陈丽娟,衣然.等保2.0时代城市轨道交通信号系统网络安全防护新思路[J].信息技术与网络安全,2020,39(3):1-5.
- [5] 吴瑛.基于安全等级保护2.0工作中可信计算问题的解决方案与思考[J].信息通信,2020(1):239-240.
- [6] 刘磊,徐鑫,张承,等.基于网络安全等级保护2.0要求的生产过程质量追溯体系建设分析[J].数字技术与应用,2019,37(7):189-190.